ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell Automation PowerFlex 753 / 755 (750-series) AC Drive · Component type: **Embedded Device (EDR) - variable frequency drive (VFD)** · Target SL = SL 3

Where to work	**CCW** or **DriveExecutive** via **FactoryTalk Linx**; the **Enhanced HIM** (20-HIM-A6/-C6S) on the drive; **Studio 5000** drive AOP when Logix-connected; **FactoryTalk Policy Manager + System Services** (CIP Security CA); **ControlFLASH Plus** + **PCDC** (firmware); **FactoryTalk AssetCentre** (audit/DR).
Ports / paths	EtherNet/IP: **TCP 44818** (explicit msg), **UDP 2222** (I/O), **UDP 44818** (ListIdentity). 20-750-ENETR web = **HTTP TCP 80** (disabled by default). CIP Security wraps EtherNet/IP in **TLS/DTLS**. Drive has no syslog/RTC - events live in **AssetCentre** / the controller. Params addressed **port:parameter**: drive host = **Port 0**, option slots 1-7, embedded ENet (755) = Port 13, DPI/HIM = Port 14.
Notes	EDR - AC drive, PowerFlex 753/755. Confirm firmware rev, the comm option (embedded 755 ENet vs 20-750-ENETR), any Safe Torque Off / 20-750-S3 safety card, and whether the comm path is CIP Security-capable. Non-capable adapters lean on compensating segmentation.
How to read	Each row = one SL-3 requirement with native step-by-step (exact HIM screen / CCW parameter) + command-level external-tool steps. Default read-only; mark Pass/Fail/Partial/N/A. Scans authorized; fuzz/flood ISOLATED lab only with written authorization.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the drive configuration backup - **Studio 5000 drive profile / DriveExecutive**, or the Enhanced HIM (20-HIM) copy (Status > Port 00 > PROPERTIES) - the full parameter export, the 20-750-ENETR web/port settings (Web Enable / Web Features), firmware rev, and the fault queue.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	The drive has no per-user login; verify the three real gates. **(1) HIM access code:** on the Enhanced HIM go **Status screen › scroll to Port 00 (host) › press the folder key › PROPERTIES folder › Change Password**; confirm a non-zero code is set (range 0-65535; **0 = disabled**), then **Log Out** in PROPERTIES to enforce it. **(2) Write protection:** in CCW open the drive › Parameters › Port 0 host params, confirm Par 324 [Logic Mask] and Par 0:230 [Write Mask Cfg] restrict command/write ports (live state = 0:231 [Write Mask Act]). **(3)** when Logix-connected, the AOP is governed by FactoryTalk Security. **Test:** from an un-logged-in HIM or an unauthorized CCW session, attempt a parameter edit -> must prompt for the access code / be refused. **Ext. tools:** `nmap -sU -p 44818 --script enip-info <drive_ip>` (identity w/o auth = exposure baseline); `curl -m5 http://<enetr_ip>/` (web should be OFF); CCW (attempt write, isolated).	HIM access code set + Write/Logic Mask restrict ports; no unauthenticated parameter change.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.2	Software process / device identification	Confirm unique identity: in CCW open the 20-750-ENETR/embedded-ENet **Host Parameters** and read the IP + host name; each controller/HMI/engineering node is a distinct EtherNet/IP identity. Under CIP Security, partners are bound by device certificate. **Ext. tools:** `nmap -sU -p 44818 --script enip-info <drive_ip>` (Vendor/Product/Serial/IP); Wireshark display filter `enip || cip` (partner IPs); FactoryTalk Policy Manager (cert identity).	Unique drive identity; comm partners identified/bound.	
SR/CR 1.3	Account management	Where FactoryTalk Security governs the AOP, review users/roles in the **FactoryTalk Administration Console** (operate vs configure vs administer) - remove defaults, least privilege. Confirm the HIM access code is held only by authorized staff and rotated; no shared "everyone knows it" code. **Ext. tools:** FactoryTalk Admin Console (Users & Groups export); access-code custody record review.	Accounts managed, least-privilege; HIM code controlled; defaults changed.	
SR/CR 1.4	Identifier management	Confirm unique FactoryTalk user IDs and a unique drive identity (EtherNet/IP address + host name in Host Parameters + drive serial from CCW device info / nameplate); no reuse across drives. **Ext. tools:** `nmap -sU -p 44818 --script enip-info` (serial/IP); FactoryTalk (user IDs); network inventory.	Unique user and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Enforce strong FactoryTalk passwords (FactoryTalk password policy). For the HIM use a non-trivial access code and store it in the credential vault, not on the panel. If the 20-750-ENETR web server is enabled, confirm it exposes no unauthenticated write, or disable it (see 7.6). **Ext. tools:** FactoryTalk Admin Console (Password/Account policy screenshot); CCW (Device Par 26 [Web Enable] value).	Strong, managed authenticators; HIM code non-default; no defaults remain.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Where CIP Security is enabled, in **FactoryTalk Policy Manager** confirm the drive holds a device certificate issued by the asset-owner CA (**FactoryTalk System Services**), valid/not-default, with a managed trust list. **Ext. tools:** FactoryTalk Policy Manager (Device › certificate status/expiry); if the ENETR web/TLS is up: `openssl s_client -connect <ip>:443 | openssl x509 -noout -subject -issuer -dates`.	CA-issued device certificate where CIP Security supported; defaults replaced.	
SR/CR 1.9	Strength of public key auth	Confirm CIP Security uses TLS/DTLS with current suites (no weak/expired certs). Where only legacy EtherNet/IP exists, record the compensating segmented-zone control. **Ext. tools:** Wireshark filter `dtls || tls` (handshake suite on the EtherNet/IP flow); FactoryTalk Policy Manager (key/algorithm review).	Strong crypto on secured channels; compensating control otherwise.	
SR/CR 1.10	Authenticator feedback	Confirm CCW/DriveExecutive logon, FactoryTalk logon, the HIM access-code entry (Enter New Password popup shows masked digits), and any adapter web login obscure the secret. **Ext. tools:** Visual verification at each interface (screenshot the masked field).	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm repeated failed FactoryTalk / adapter-web logins are locked/throttled and recorded (FactoryTalk lockout policy). The HIM access code has no lockout - record as residual, mitigated by physical control + monitoring. **Ext. tools:** FactoryTalk Admin Console (lockout policy screenshot); SIEM query for failed-auth from the EWS.	Failed logins locked/throttled/logged; HIM residual noted.	
SR/CR 1.12	System use notification	The drive/HIM has no native logon banner; enforce the approved use notice on the engineering workstation (Windows GPO logon banner) and on the HMI as a compensating control. **Ext. tools:** EWS `gpresult /h gp.html` (confirm legalnoticetext); HMI banner screenshot.	Approved use notice at EWS/HMI (compensating at drive).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the drive EtherNet/IP is reachable only from the trusted cell zone behind the cell firewall / Stratix ACLs; remote engineering only via VPN. **Test:** from a host on an untrusted VLAN, scan the drive - it must not answer. **Ext. tools:** `nmap -Pn -sTU -p 44818,2222,80 <drive_ip>` from the untrusted side (expect filtered/no response); firewall/ACL rule export review.	Access from untrusted networks denied/brokered; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Verify least-privilege command/config: (1) Par 324 [Logic Mask] - only intended port bits set, so only authorized ports issue Start/Jog/Direction (Stop is never masked by design). (2) Par 0:230 [Write Mask Cfg] restricts which ports may write parameters. (3) FactoryTalk Security limits who may open/change the AOP. **Test:** from a port whose Logic-Mask bit is clear, issue Start -> refused; from a non-write port, write a parameter -> refused. **Ext. tools:** CCW (read Par 324 / 0:230, screenshot); low-privilege FactoryTalk account negative test; attempt unauthorized Start/write (isolated).	Logic Mask + Write Mask + FactoryTalk enforce least privilege; negative test confirms denial.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the engineering laptop and any USB/SD on option modules; removable-media policy on the EWS; only authorized CCW/DriveExecutive projects loaded. **Ext. tools:** EWS removable-media GPO / device-control console review; physical inspection of drive USB/SD slots.	Portable/engineering media controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code on the drive; confirm only firmware + configured parameters run and the 20-750-ENETR web content (if enabled) is vendor read-only diagnostics (no user script path). **Ext. tools:** CCW (Device Par 26 [Web Enable]=0 preferred); if web on, browse `http://<enetr_ip>/` read-only to confirm no write forms.	Only trusted firmware/config runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm CCW/adapter sessions time out on inactivity and require re-auth; after the HIM inactivity timeout the keypad reverts to a non-editing state requiring the access code to edit again. **Ext. tools:** CCW/adapter timeout config; HIM idle-timeout observation (leave idle, retry edit -> access-code prompt).	Sessions lock/timeout on inactivity; re-auth required.	
SR/CR 2.6	Remote session termination	Confirm remote engineering / adapter sessions can be terminated and idle sessions close; the port access limits who can reconnect. **Ext. tools:** FactoryTalk Linx (connection list / drop session); Wireshark (confirm session teardown).	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent programming/monitoring connections are bounded and monitored; the drive/adapter CIP connection limit prevents conflicting simultaneous configuration. **Ext. tools:** CCW/adapter connection-status page; Wireshark (count concurrent CIP sessions).	Concurrent privileged sessions limited/monitored.	
SR/CR 2.8	Auditable events	Confirm configuration/firmware changes are captured in **FactoryTalk AssetCentre** (Audit + Disaster Recovery) with the acting user; read the drive fault/alarm queue at **HIM › Diagnostics › Faults** (or CCW fault codes); forward AssetCentre/EWS events to the SIEM. **Ext. tools:** AssetCentre (Audit log filtered to the drive - user/action/time); HIM/CCW fault queue export; SIEM search for the forwarded events.	Config/firmware changes audited and attributable.	
SR/CR 2.9	Audit storage capacity	The drive fault/alarm queue is a fixed depth; retention is via AssetCentre / SIEM - confirm DB sizing and threshold alerting. **Ext. tools:** AssetCentre DB size/retention config; SIEM index-capacity alert review.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/AssetCentre alerts on forwarding/collection failure so events are not silently lost. **Ext. tools:** SIEM (source-silent/health alert rule); AssetCentre collector health.	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	The drive has no independent RTC; event time comes from the controller/AssetCentre - confirm those are NTP-synced. **Ext. tools:** `w32tm /query /status` (EWS) / controller time source; Wireshark filter `ntp`.	Reliable, synchronized timestamps for drive events.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: the removable HIM (lock the cabinet or fit a blank/keyed HIM), option-module ports, USB/SD, DPI. Optionally disable HIM Start (750-PM100 local-mask / disable-HIM-start procedure). Disable the 20-750-ENETR web server if unused: Device Par 26 [Web Enable] = 0 (default). **Ext. tools:** Physical inspection; CCW (Device Par 26 = 0; HIM-start/local-mask config); `curl -m5 http://<enetr_ip>/` (expect connection refused when disabled).	Physical/diagnostic interfaces controlled; web disabled unless required.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Enable **CIP Security** (integrity + optional confidentiality) between controller and drive where the comm option supports it; segment EtherNet/IP so unauthenticated CIP never crosses a zone boundary. **Test:** capture the controller-drive flow and confirm it is DTLS/TLS-wrapped, not cleartext CIP. **Ext. tools:** Wireshark filter `enip || cip || dtls` (secured vs cleartext); `nmap -sU -p 44818 --script enip-info` (plain identity still answers = not enforced); FactoryTalk Policy Manager.	Comms integrity-protected (CIP Security) where supported; contained otherwise.	
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Rockwell-**signed** drive firmware runs. 750-series firmware ships as signed .dmk; ControlFLASH Plus/the drive validates the signature and rejects unsigned/altered images. **Ext. tools:** ControlFLASH Plus (select the .dmk -> it shows Signed/verified); cross-check the file SHA-256 against **PCDC** (`certutil -hashfile firmware.dmk SHA256`).	Only signed firmware runs; component protected from malicious code.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: CIP Security state, 0:230 Write Mask, 324 Logic Mask, HIM access code set, Device Par 26 [Web Enable], and access level, against the hardening baseline. **Ext. tools:** CCW compare (current params vs archived baseline project); `nmap -sTU -p 44818,2222,80 <ip>` (confirm web/unused services still off).	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Archive the parameter set / CCW project in AssetCentre, enable change detection, and keep 0:230 Write Mask restrictive so unauthorized parameter/firmware change is prevented/detected. **Ext. tools:** AssetCentre (Change Detection schedule + diff report); CCW online-vs-offline parameter compare.	Config integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm the drive tolerates malformed EtherNet/IP/CIP frames without faulting or unsafe motion. **ISOLATED only:** fuzz the EtherNet/IP interface on a bench drive and watch the fault queue / connection status. **Ext. tools:** ENIP/CIP fuzzer (`boofuzz` ENIP harness or Defensics EtherNet/IP) on a bench drive; Wireshark to correlate crashes; watch HIM fault queue.	No crash or unsafe motion on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic output	Verify the fault / comm-loss reaction so the motor reaches a defined safe state: set the comm option **Comm Flt Action** and **Idle Flt Action** (20-750-ENETR host params) and the drive **Fault Config** to Fault/Stop as designed; where fitted, function-test **Safe Torque Off** / the **20-750-S3 Safe Speed Monitor**. **Test:** pull the network cable -> drive takes the configured comm-loss action; trigger STO -> torque removed. **Ext. tools:** CCW (Comm/Idle Flt Action + Fault Config screenshot); STO/S3 function test (lab, per safety manual).	Drive assumes a defined/safe state (coast/stop/STO) on fault or comm loss.	
SR/CR 3.7	Error handling	Confirm graceful fault handling: review the fault/alarm queue and the configured fault actions (auto-restart disabled unless justified) so errors do not cause loss of control or unsafe restart. **Ext. tools:** CCW/HIM (Diagnostics › Faults + fault-action params; Auto Rstrt Tries = 0 unless justified).	Graceful fault handling; no unsafe restart or info leak.	
SR/CR 3.8	Session integrity	Where CIP Security is applied, sessions are integrity-protected against replay/hijack; confirm secured channels in use and legacy unauthenticated sessions contained by the zone. **Ext. tools:** Wireshark (confirm DTLS/TLS session, no plain CIP replay path).	Sessions integrity-protected where supported; contained otherwise.	
SR/CR 3.9	Protection of audit information	Protect the AssetCentre audit database and Syslog transport; restrict who can read/clear the drive fault queue and the AssetCentre change records. **Ext. tools:** AssetCentre (DB/role permissions review); SIEM (index access roles).	Audit records protected from unauthorized read/modify/delete.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 3.10	Support for updates	Update firmware only with Rockwell-signed .dmk via **ControlFLASH Plus** (signature validated); plan the update in a maintenance window with a documented rollback to the prior signed revision; cross-check the file against PCDC before flashing. **Ext. tools:** ControlFLASH Plus (Signed indicator); `certutil -hashfile firmware.dmk SHA256` vs PCDC published hash.	Signed firmware updates only, with a controlled update + rollback path.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the drive in a locked, sealed cabinet; control the HIM (removable) and option-module/USB/SD; the AssetCentre audit and drive fault/event queue record config/firmware changes as tamper evidence. **Ext. tools:** Physical inspection (locks/seals); AssetCentre / HIM fault-queue review for unexpected changes.	Cabinet locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The drive accepts only Rockwell-signed firmware (product-supplier root of trust); confirm the signing chain is intact and an unsigned/altered .dmk is rejected at load. **Test:** attempt to flash a tampered/unsigned .dmk on a bench drive -> ControlFLASH Plus/the drive rejects it. **Ext. tools:** ControlFLASH Plus (signature verify); isolated unsigned-image attempt -> rejected.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.
EDR 3.13	Provisioning asset-owner roots of trust	For CIP Security, confirm the asset owner's **FactoryTalk System Services** is the CA and the drive is enrolled with its certificate managed in **FactoryTalk Policy Manager**; else record the compensating control. **Ext. tools:** FactoryTalk Policy Manager / System Services (CA identity + drive enrollment status).	Asset-owner certificate provisioning verified, or compensating recorded.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the drive validates signed-firmware integrity before execution; capture the firmware revision + signed status at **HIM › Diagnostics › Version** (or CCW device info). **Ext. tools:** CCW/HIM (firmware revision + signed status screenshot); ControlFLASH Plus.	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, in CCW/HIM **reset the drive to defaults** (Par 0:8 [Reset To Defalts] / Set Defaults) and clear option-module config; sanitize/destroy any SD used so drive configuration is not recoverable. **Ext. tools:** CCW/HIM (Par 0:8 Set Defaults, confirm); option-media sanitize per media-handling policy.	Sensitive configuration purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Where CIP Security is enabled, confirm modern crypto (TLS/DTLS, strong suites); disable the legacy adapter web server (Device Par 26 [Web Enable]=0) or restrict it; certificates managed in FactoryTalk. **Ext. tools:** Wireshark `dtls||tls` (suite); if web/TLS up: `testssl.sh https://<ip>`; Policy Manager review.	Modern crypto where supported; legacy services disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the drive sits in a controlled cell/zone behind a firewall / **Stratix** ACLs / **SCALANCE**; only required EtherNet/IP flows cross the boundary; no flat convergence with IT. Primary compensating control for non-CIP-Security adapters. **Ext. tools:** `nmap -sTU -p 44818,2222,80 <drive_ip>` from each zone (only required ports open from authorized zones); firewall/ACL rule export.	Drive in a segmented zone; only required flows cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR 5.3	General-purpose person-to-person comms restrictions	Largely **N/A**, but note: the 20-750-ENETR (Adapter mode) can send **fault email notifications**. Confirm the drive originates no such messaging - keep Device Par 26 [Web Enable]=0, and if email is used protect it via Device Par 27 [Web Features] Bit 0. **Ext. tools:** CCW (Device Par 26=0; Device Par 27 Bit0 set if email configured); ENETR web Email Notification page review if enabled.	N/A / any email-notification feature disabled or protected.	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose drive; no separable applications to partition (handled at the controller/SCADA layer). **Ext. tools:** Confirm single-function device (no general-purpose OS/app services on the drive).	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm drive faults/alarms (HIM/CCW fault queue) and AssetCentre change records are readable/exportable and forwarded to the SIEM; the cell is passively monitored (OT IDS on a mirror port). **Ext. tools:** AssetCentre (export change/audit report); passive OT IDS on a SPAN port (Nozomi/Dragos/Frenos) shows the drive and its flows.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the drive/adapter CIP connection limits plus cell-firewall rate-limiting prevent a flood from denying control; monitor connection load and drive comms status while testing. **Ext. tools:** ISOLATED bench: `hping3 --flood -2 -p 2222 <drive_ip>` / ENIP connection storm; watch HIM comms status + fault queue.	Resources bounded; drive control continues under load.	
SR/CR 7.2	Resource management	Confirm the drive/comm adapter bounds resource use (max CIP connections, comms load) so a single service cannot starve control. **Ext. tools:** CCW/adapter (connection limit + comms-load counters); Wireshark (connection count).	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3	Control system backup	Confirm the drive parameter set / CCW project and option-module config are backed up (AssetCentre Disaster Recovery, versioned, offline) and a restore is tested for a known-good rebuild. **Ext. tools:** AssetCentre (DR schedule + last-good archive); restore to a spare/lab drive (recovery test).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Confirm hardening per baseline: disable the 20-750-ENETR web server (Device Par 26 [Web Enable]=0) if unused, disable unused option-module functions/ports, set 0:230 Write Mask and 324 Logic Mask restrictively, and set a HIM access code. **Ext. tools:** CCW (Device Par 26=0; masks; unused-port config); `nmap -sTU -p 44818,2222,80 <ip>` (only required services reachable).	Least functionality; unused services disabled per baseline.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the drive (catalog, firmware rev, option modules, comm adapter) is inventoried so vulnerabilities track against Rockwell Automation security advisories (PN1xxx). **Ext. tools:** `nmap -sU -p 44818 --script enip-info` (product/rev); CCW/AssetCentre asset inventory export.	Accurate component/firmware inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
CCW / DriveExecutive / Studio 5000	Native config & protection review (all FRs)	Connect via FactoryTalk Linx; open the drive › Parameters. Read Par 324 [Logic Mask], Par 0:230 [Write Mask Cfg], Device Par 26 [Web Enable], fault/comm-loss actions, firmware rev; export the project as the baseline and diff on later reviews.	Read/authorized project copy.
Enhanced HIM (20-HIM-A6/-C6S)	On-drive review (1.1, 2.13, 3.14)	Status › Port 00 › PROPERTIES › Change Password (set access code, 0=off); Diagnostics › Faults (fault queue); Diagnostics › Version (firmware/signed status).	Physical; authorized.
FactoryTalk Policy Manager / System Services	CIP Security CA, certs, enrollment (1.8, 3.1, 3.13)	Open the security model; confirm the drive is enrolled, its certificate is CA-issued/valid, and the trust list is managed.	Read-only.
FactoryTalk AssetCentre	Audit, change detection & DR (2.8, 3.4, 6.x, 7.3)	Filter the Audit log to the drive (user/action/time); schedule Change Detection; use Disaster Recovery for versioned backup + restore test.	Non-intrusive.
ControlFLASH Plus / PCDC	Signed firmware update & verify (3.2, 3.10, 3.12, 3.14)	Select the .dmk in ControlFLASH Plus (shows Signed); cross-check with `certutil -hashfile firmware.dmk SHA256` vs the PCDC-published hash; rollback path = prior signed .dmk.	Maintenance window.
nmap	EtherNet/IP identity, exposure, segmentation (1.1, 1.2, 1.13, 5.x, 7.6, 7.8)	`nmap -sU -p 44818 --script enip-info <ip>` (Vendor/Product/Serial/rev). `nmap -Pn -sTU -p 44818,2222,80 <ip>` from each zone to prove segmentation.	Read-only; tune timing on production.
Wireshark / tcpdump	Comms integrity & identity (1.2, 3.1, 3.8, 2.11)	SPAN/tap the cell; filter `enip || cip || dtls` to confirm CIP Security wrapping (or cleartext), partner IPs, and NTP.	Passive; SPAN/tap only.
openssl / testssl.sh	TLS on ENETR web / CIP Security (1.8, 1.9, 4.3)	`openssl s_client -connect <ip>:443 | openssl x509 -noout -subject -issuer -dates`; `testssl.sh https://<ip>` for suite/cert grade (only if web/TLS is enabled).	Non-intrusive.
ENIP/CIP fuzzer / hping3	Input validation & DoS resilience (3.5, 7.1)	`boofuzz` ENIP harness / Defensics EtherNet/IP on a bench drive; `hping3 --flood -2 -p 2222 <ip>` connection storm; watch fault queue + comms status.	ISOLATED/non-production; written authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.